

Comparison of Static Application Security Testing Tools and Large Language Models for Repo-level Vulnerability Detection

Xin Zhou
Singapore Management University
Singapore
xinzhou.2020@phdcs.smu.edu.sg

Duc-Manh Tran
Hanoi University of Science and
Technology
Vietnam
manh.td120901@gmail.com

Thanh Le-Cong
The University of Melbourne
Australia
congthanh.le@student.unimelb.edu.au

Ting Zhang
Singapore Management University
Singapore
tingzhang.2019@phdcs.smu.edu.sg

Ivana Clairine IRSAN
Singapore Management University
Singapore
ivanairsan@smu.edu.sg

Joshua SUMARLIN
Singapore Management University
Singapore
jsumarlin.2022@scis.smu.edu.sg

Bach Le
University of Melbourne
Australia
bach.le@unimelb.edu.au

David Lo
Singapore Management University
Singapore
davidlo@smu.edu.sg

ABSTRACT

Software vulnerabilities pose significant security challenges and potential risks to society, necessitating extensive efforts in automated vulnerability detection. There are two popular lines of work to address automated vulnerability detection. On one hand, Static Application Security Testing (SAST) is usually utilized to scan source code for security vulnerabilities, especially in industries. On the other hand, deep learning (DL)-based methods, especially since the introduction of large language models (LLMs), have demonstrated their potential in software vulnerability detection. However, there is no comparative study between SAST tools and LLMs, aiming to determine their effectiveness in vulnerability detection, understand the pros and cons of both SAST and LLMs, and explore the potential combination of these two families of approaches.

In this paper, we compared 15 diverse SAST tools with 12 popular or state-of-the-art open-source LLMs in detecting software vulnerabilities from repositories of **three popular programming languages: Java, C, and Python**. The experimental results showed that SAST tools obtain low vulnerability detection rates with relatively low false positives, while LLMs can detect up 90% to 100% of vulnerabilities but suffer from high false positives. By further ensembling the SAST tools and LLMs, the drawbacks of both SAST tools and LLMs can be mitigated to some extent. Our analysis sheds light on both the current progress and future directions for software vulnerability detection.

1 INTRODUCTION

The early detection and mitigation of software vulnerabilities is crucial, as unaddressed vulnerabilities can potentially lead to consequences like massive economic losses and compromised critical infrastructure. With the number of software vulnerabilities significantly increasing from 5,697 in 2013 to 29,065 in 2023 [72], the impact of software vulnerabilities has also amplified. Accurately and promptly identifying vulnerabilities is crucial for mitigating potential risks and has garnered significant attention from both industry and academia.

Static Application Security Testing (SAST) tools are commonly used in industries to scan source code and detect vulnerabilities. These tools analyze code without executing it, using techniques such as syntax, data flow, and control flow analysis [18]. SAST is popular due to its low cost, fast operation, and ability to find bugs without running the program [49]. Meanwhile, in the research community, large language model (LLM)-based methods have demonstrated their effectiveness for function-level software vulnerability detection [29, 55], which predict whether a function contains the vulnerability or not. LLMs are deep learning (DL) models based on the Transformer architecture [78], comprising a vast number of parameters and pre-trained on massive amounts of source code, text, and other data modalities [11, 58]. Recently, LLMs have seen a significant increase in the size of their pre-training data and model parameters [56, 59]. The extensive knowledge acquired through the large-scale pre-training offers the potential to substantially improve the effectiveness of vulnerability detection.

Despite the considerable research interest in either SAST tools or LLMs for vulnerability detection, a comprehensive comparative study between these two popular approaches has been lacking. This gap can be attributed to the following three major **challenges**:

Lack of a repo-level vulnerability detection formulation: SAST tools are usually used to detect vulnerabilities across entire code repositories. However, current DL-based methods for vulnerability detection, including those utilizing LLMs, primarily focus on identifying vulnerabilities within individual functions [12, 27, 55, 84, 88]. To date, we are unaware of any DL-based methods that are designed to detect vulnerabilities at the level of entire repositories. This gap in methodology hinders a fair and direct comparison between SAST tools and LLMs. Therefore, there is a need for a new task formulation for repo-level vulnerability detection.

Lack of datasets supporting both SAST and LLMs: Existing datasets for DL-based or LLM-based vulnerability detection, such as BigVul [25] and CVEfixes [9], contain labeled data at the function level without the source code of complete repositories, which is not

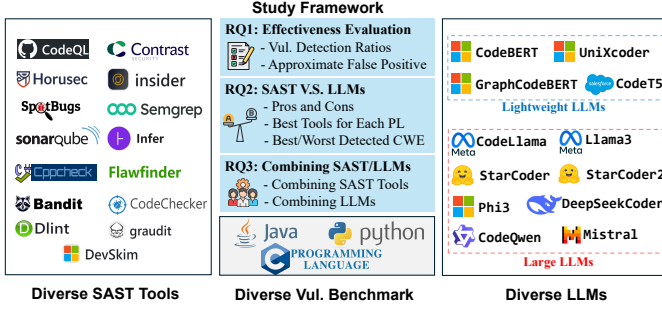


Figure 1: Overview of Our Study

suitable for conducting experiments at the repository level. Thus, there is a need for datasets that contain the complete source code of vulnerable repositories, which are suitable for evaluating both SAST and LLM-based approaches.

Lack of a comprehensive LLM evaluation framework: Recently, there has been a proliferation of diverse LLMs [41], and their implementations could vary in terms of model architectures (i.e., encoder-only, decoder-only, encoder-decoder). Moreover, adapting these LLMs to specific downstream tasks, such as repo-level vulnerability detection, often could employ various adaptation techniques. These techniques include zero-shot prompting [11], few-shot prompting [11], chain-of-thought prompting [47], and fine-tuning [27, 40], etc. Given the complexity and diversity of LLMs, there is a need for a unified LLM evaluation framework that can support the diverse LLMs and various adaptation techniques.

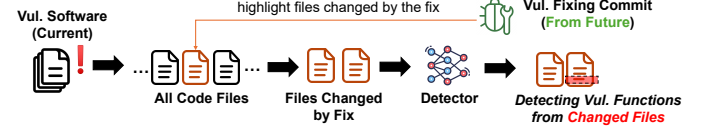
To tackle these challenges, in this paper, we conduct a comprehensive study as shown in Figure 1, aimed at comparing SAST tools with LLMs in detecting software vulnerabilities from repositories. Firstly, we formulate a novel task that enables LLMs to conduct repo-level vulnerability detection. The task involves identifying the vulnerability from a given software repository. Secondly, we have curated three datasets for repo-level vulnerability detection, each tailored to a widely used programming language: Java, C, and Python. This diverse set of evaluation datasets enable us to gain insights into the proficiency of SAST tools and LLMs in detecting vulnerabilities across these different popular programming languages. Thirdly, we implement a comprehensive evaluation framework encompassing 12 distinct LLMs with diverse architectures (encoder-only, decoder-only, encoder-decoder) and parameter sizes ranging from 120 million to 8 billion parameters.

Our experiments yield the following key **findings**:

- (1) SAST tools obtained low vulnerability detection ratios (up to 44.4%) and many failed to detect any vulnerabilities.
- (2) LLMs achieved high vulnerability detection rates (up to 90% to 100%) but they were accompanied by high false positive rates.
- (3) By combining multiple SAST tools, we observed a substantial increase (i.e., 25.2%–100.0%) in vulnerability detection rates. Combining diverse LLMs led to a substantial reduction (i.e., 40.9%–74.6%) in false positive rates.
- (4) The best approach differs across programming languages if considering both detection rates and false positive rates. For Java, the combined LLMs provide the most effective solution, while for C and Python, the combined SAST tools are the best.

Contributions. In summary, our contributions are as follows:

Function-level Vul. Detection



Ours: Repo-level Vul. Detection

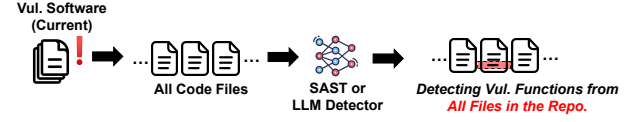


Figure 2: Repo-level and Function-level Vul. Detection

- To the best of our knowledge, we are the first to comprehensively compare the SAST tools with LLMs in three popular programming languages, Java, C, and Python.
- We are the first to introduce the task of repo-level vulnerability detection and evaluate twelve diverse LLMs on this task.
- We have constructed a new repo-level Python vulnerability dataset and curated Java and C vulnerability datasets, facilitating evaluation across multiple popular programming languages.
- As far as we know, we are the first to evaluate the SAST tools in detecting real-world vulnerabilities in Python repositories.
- We conduct an extensive evaluation of 15 SAST tools and 12 LLMs, including four different LLM adaptation techniques. We identify the best-performing approaches and discuss implications for future studies on vulnerability detection.

2 STUDY DESIGN

In this section, we present our proposed repo-level vulnerability detection task. We then introduce the data collection and detail the study objects (i.e., SAST tools and LLMs).

2.1 Repo-level Vulnerability Detection

We first introduce our proposed repo-level vulnerability detection task and then compare it with the function-level vulnerability detection task used in existing studies [12, 27, 88].

2.1.1 Repo-level Vulnerability Detection Task Formation. This task aims to detect the vulnerable functions in an entire repository. It aims to learn a detector M that can map the source code of an entire repository to vulnerability labels at the function level:

$$M : \mathcal{X} \mapsto \mathcal{Y}, \quad \mathcal{X} = \{x_0, x_1, \dots, x_n\} \text{ and } \mathcal{Y} = \{0, 1, \dots, 0\}$$

where $\mathcal{X}$ denotes the entire input repository and its component x_i refers to the i -th function in the input repository. n refers to the number of functions in the input repository. $\mathcal{Y}$ denotes the labels of all functions in the repository, where 1 indicates a vulnerable function and 0 indicates a clean (non-vulnerable) function.

2.1.2 Comparison with Function-level Vulnerability Detection. The function-level vulnerability detection aims to predict whether a target function contains a vulnerability or not [12, 88]. To understand the difference between function-level and repo-level vulnerability detection, we need to briefly explain what the “target functions” are in the function-level vulnerability detection dataset/task.

Many function-level vulnerability detection datasets, such as BigVul [25], ReVeal [12], CrossVul [62], CVEfixes [9], and DiverseVul [14], employ a heuristic to automatically label functions, as

depicted in Figure 2. Firstly, they collect vulnerability-fixing commits from databases like NVD. They then label the pre-commit versions of functions changed by the vulnerability-fixing commits as vulnerable functions. Additionally, they label all unchanged functions in the changed code files in vulnerability-fixing commits as non-vulnerable. Thus, the “target functions” are functions in the changed code files of vulnerability-fixing commits. As shown in the bottom part of Figure 2, in contrast, our proposed repo-level vulnerability detection aims to detect vulnerable functions given all functions in the repository. Thus, the repo-level task has a much broader detection scope. For instance, the ratios of vulnerable functions in the function-level vulnerability detection datasets BigVul [25], ReVeal [12], CrossVul [62], CVEfixes [9], and DiverseVul [14] range from 4.5% to 9.2%. In contrast, the vulnerable function ratios in our studied repo-level vulnerability detection datasets are substantially lower, ranging from 0.008% to 0.18% as shown later in Table 1.

We propose the repo-level vulnerability detection task for two reasons: (1) The repo-level task is more aligned with the tasks performed by SAST tools, which usually check the entire repository to detect vulnerabilities; (2) Limiting the detection range to only the changed files in vulnerability-fixing commits is not a practical approach for vulnerability detection. This is because when vulnerabilities are yet to be discovered and addressed, the corresponding vulnerability-fixing commits do not exist. Therefore, it is better not rely on such commits to narrow down the detection scope from the entire repository into files changed in vulnerability-fixing commits.

2.1.3 Applying LLMs for Repo-level Vulnerability Detection. For the repo-level vulnerability detection task, the goal is to detect vulnerable functions across all functions within an entire repository. However, repositories can be extremely lengthy, while some of the studied LLMs, such as CodeBERT and GraphCodeBERT, have input length limitations of 512 tokens. This 512-token limit aligns well with function-level data but not with classes or entire repositories. Although some larger studied LLMs allow wider input ranges (e.g., up to 8,192 tokens for StarCoder [50]), we aim to conduct experiments within the same setting for all studied LLMs. To enable all LLMs, including LLMs like CodeBERT, to perform the repo-level task, we employ the following strategy unified across all LLMs: (1) We split a repository into individual functions. (2) We predict the vulnerability label for each function in the repository separately. (3) We aggregate all predictions for the functions within the repository to obtain the predictions for the entire repository. (4) We analyze whether vulnerabilities are detected within the repository based on the aggregated predictions (See Sections 3.1 and 3.2 for details).

2.2 Vulnerability Datasets

In this paper, we investigate three datasets for three popular programming languages, i.e., Java, C, and Python. Specifically, the Java and C datasets are sourced from Li et al. [49] and Lipp et al. [51]. The Python dataset is newly constructed. The statistics of three datasets are shown in Table 1. Please note that for each CVE entry, our datasets provided 1) CVE ID, 2) CWE type, 3) the complete source code of the corresponding vulnerable software, and 4) locations of vulnerabilities at the function level.

Java and C Vulnerability Datasets. For the Java vulnerability dataset selection, we considered the Java dataset shared by Li et

Table 1: Statistics of the Used Datasets.

Dataset	#Project	#CVE	#Functions	Vul. Ratio
Java	50	87	3,986,848	0.008%
C	6	85	1,181,556	0.009%
Python	78	98	312,045	0.18%

al. [49], as it contains real-world vulnerabilities, in contrast to synthetic datasets such as the Juliet Test Suite Java [65]. This dataset contains CVE IDs, project names, and the locations of vulnerabilities labeled at the function level. However, the authors of the dataset did not share the actual repositories of the vulnerable Java software. To obtain the complete source code of vulnerable repositories, we searched for the vulnerable repositories with the provided version IDs and project names on GitHub. We only selected the repositories that we could successfully download through GitHub APIs. In total, we obtained 87 CVE entries and the corresponding vulnerable repositories. Next, we utilized Tree-sitter [1] to parse and slice each vulnerable repository into individual function-level code snippets. For the C vulnerability dataset selection, we considered the dataset shared by Lipp et al. [51] which contains real-world vulnerabilities. Similarly, this dataset contains CVE IDs, and project names but not the actual vulnerable C repositories. To obtain the complete source code of vulnerable repositories, we followed the instructions of the authors and successfully obtained the vulnerable repositories of 85 CVE entries. Next, we utilized Tree-sitter [1] to parse and slice each vulnerable repository into individual function-level code snippets.

Python Vulnerability Dataset. Python is one of the most popular programming languages [75], with a broad range of application scenarios. However, there has been a lack of research effort in two aspects. Firstly, although previous studies [49, 51] have evaluated SAST tools for C and Java respectively, their findings may not be directly applicable to Python due to the differences in language semantics and characteristics. Secondly, other studies on applying LLMs to detect vulnerabilities have primarily focused on C/C++ [9, 25, 88], leaving a research gap for Python. To address this gap, we have constructed a new dataset of real-world Python vulnerabilities.

We first downloaded all available vulnerability data in JSON format from the National Vulnerability Database (NVD) from 2002 to 2023. We then parsed this data and extracted GitHub Python repositories by collecting the reference URLs of these vulnerabilities. We then identified the fixing commits for each vulnerability by checking the reference links provided in the vulnerability reports. Subsequently, we selected the repositories from which we can retrieve complete source code via GitHub. We omitted projects that encountered errors during scanning with SAST tools. Through these steps, we curated a dataset comprising a total of 98 CVE entries related to Python projects hosted on GitHub.

To identify the vulnerable functions from vulnerability-fixing commits, we adopted the approach proposed by previous methods [9, 25, 88]. First, we collected the software versions prior to each vulnerability-fixing commit, which are regarded as vulnerable versions. Then, we labeled the functions containing lines of code that were modified in the fixing commit as vulnerable. All other functions present in the vulnerable version were considered non-vulnerable. Although these other functions could potentially harbor vulnerabilities that have not been discovered by the community, in this work, we aim to assess whether the SAST tools/LLMs could accurately identify known vulnerabilities. Therefore, we assume that

it is reasonable to label all functions, except the known vulnerable ones, as non-vulnerable.

2.3 SAST Tools Selection

Java and C SAST Tools. For Java SAST tools, we followed Li et al. [49] to select 7 free or open-source SAST tools that support Java code: CodeQL [16], Contrast CodeSec Scan (Contrast) [69], Horusec [89], Insider [43], SpotBugs [64], Semgrep [70], and SonarQube community edition (SonarQube) [71]. These tools encompass a diverse range of SAST techniques and are popular among developers, as indicated by the number of GitHub stars [49]. For C SAST tools, we followed Lipp et al. [51] to select five free or open-source SAST tools that support C code, i.e., Flawfinder [28], Cppcheck [17], Infer [42], CodeChecker [15], and CodeQL [16]. These tools implemented state-of-the-art analysis techniques [51] and were used in previous studies focusing on evaluating SAST tools [51, 73].

Python SAST Tools. We aim to select a representative set of SAST tools that support Python code. For the search range, we utilized a comprehensive set of 576 candidate SAST tools identified by Li et al. [49]. They compiled their list by searching tool lists from recent literature (e.g., [4, 32, 52]) and obtaining recommendations for SAST tools from several prominent websites (e.g., GitHub, NIST, and Wikipedia). We designed the following criteria to select SAST tools for Python: 1) Python supported: we included only SAST tools that support Python programs; 2) Free of charge: due to the substantial costs of commercial tools, we followed Li et al. [49] to select the free Python SAST tools; 3) Security-related: we selected tools that identify generalized security vulnerabilities rather than those aimed at detecting specific vulnerabilities or code quality issues; 4) Well-documented with detecting rules: we selected SAST tools with clear documentation. Based on these criteria, we finally selected six SAST tools: Bandit [7], Dlint [23], DevSkim [21], CodeQL [16], Graudit [33], and Semgrep [70].

2.4 Studied LLMs

We focus on free and open-source LLMs instead of commercial LLMs such as GPT-3.5 and GPT-4 for two primary reasons. Firstly, the cost of utilizing commercial LLMs to scan entire repositories for vulnerability detection is prohibitively high. As illustrated in Table 1, the datasets contain 312,045 to 3,986,848 functions, making the use of commercial LLMs financially challenging for such large-scale tasks. Secondly, commercial LLMs undergo continuous updates, making it difficult to replicate and validate the results. In contrast, open-source LLMs offer greater transparency and accessibility, facilitating reproducible evaluations.

Table 2 summarizes the characteristics of the studied LLMs. Please note that in accordance with a recent comprehensive survey on large language models for Software Engineering [39], we categorize CodeBERT, GraphCodeBERT, CodeT5, and UniXcoder as LLMs, though their model sizes may be considered relatively small within the LLM spectrum. Specifically, we select two groups of open-source LLMs: 1) general LLMs and 2) code-related LLMs. General LLMs are pre-trained on diverse data, including natural language and code, and can be utilized for various tasks. In contrast, code-related LLMs are specifically (further) pre-trained on code-related data. Given the empirical nature of this study, we

Table 2: Overview of Studied LLMs.

	Model	#Param.	Type	Release Date	Code Gene. (HumanEval) Pass@1	Adaptation Techniques
Light-weight LLMs (<1B)	CodeBERT	0.13B	Enc	Jul. 2020	-	Full Fine-tuning
	G-BERT	0.13B	Enc	Feb. 2021	-	
	CodeT5	0.22B	Enc-Dec	Sep. 2021	-	
	UniXcoder	0.13B	Enc-Dec	Mar. 2022	-	
Large LLMs (≥1B)	StarCoder	7B	Dec	May 2023	20.4%	PEFT, Zero-shot Prompt, Few-shot Prompt, CoT Prompt
	CodeLlama	7B	Dec	Aug. 2023	45.7%	
	Mistral	7B	Dec	Sep. 2023	-	
	DSCoder	6.7B	Dec	Dec. 2023	80.2%	
	StarCoder2	7B	Dec	Feb. 2024	34.1%	
	CodeQwen	7B	Dec	Apr. 2024	50.8%	
	Llama3	8B	Dec	Apr. 2024	62.2%	
	Phi3	3.8B	Dec	May 2024	58.5%	

aim to assess the effectiveness of both LLM categories in the repo-level vulnerability detection task. For code-related LLMs, we select the five recently released and leading models (in 2023 or 2024): DeepSeek-Coder (DSCoder) [19], CodeLlama [58], StarCoder [50], StarCoder2 [56], and CodeQwen [6]. Additionally, we select four popular and lightweight code-related LLMs with parameters less than 1 billion: CodeBERT [27], GraphCodeBERT (G-BERT) [35], CodeT5 [79], and UniXcoder [34]. Regarding general LLMs, we select three recently released models: Mistral [3], Phi3 [60], and Llama3 [59]. Since LLM families have different model sizes, we select models with no more than **8B parameters**. This constraint on the model parameters is imposed by our computing resources (NVIDIA RTX A5000).

2.5 LLM Adaptation Techniques

We employ two typical techniques for adapting LLMs: prompt-based methods and fine-tuning-based methods. The last column of Table 2 summarizes the corresponding LLM adaptation techniques used for each of the studied LLMs.

2.5.1 Prompt-based Methods. Prompts act as guides for LLMs, formatting the input data and providing a natural language description of the task [11]. Prompt-based methods mainly leverage the pre-trained knowledge of LLMs to perform the downstream task without the need for extensive task-specific training. The prompt format designed for our vulnerability detection task comprises three components, organized sequentially: 1) Task Description: a natural language description of the vulnerability detection task, i.e., “If the following code snippet has any vulnerabilities, output Yes; otherwise, output No”; 2) Formatted Input: the input code is enclosed within two markers “// Code Start” and “// Code End”; 3) Prediction Marker: a marker (“// Detection”) instructing the model to start to provide its prediction.

We studied three popular prompt-based methods based on the aforementioned prompt designed for vulnerability detection:

Zero-shot Prompting: In this approach, the input source code is formatted based on the prompt above and then being inputted into LLMs. The LLMs then generate a response to detect whether the source code is vulnerable or not. It is named “zero-shot” because no labeled data is used in this approach.

Chain-of-thought (CoT) Prompting: We utilized the Chain-of-thought technique proposed by Kojima et al. [47] for improved reasoning, which involves adding “Let’s think step by step” to the original prompt. Specifically, we add the “Let’s think step by step” after the task description of the prompt above.

Few-shot Prompting: In this approach, we provided a few examples of inputs and ground truth label pairs for LLMs. Those input-label pairs are concatenated after the original prompt. Specifically, we randomly select 2 examples from the training set, one vulnerable function, and one clean function. Those examples can help the model to better understand the target task and reply in the same format as the example responses.

2.5.2 Fine-tuning-based Methods. Fine-tuning is another widely used adaptation technique for LLMs, which often unlocks their full potential for specific tasks [80]. Fine-tuning involves training an LLM on task-specific data, enabling it to acquire domain knowledge and generate more relevant and meaningful output. In this study, we considered two different fine-tuning approaches based on the size of the LLM models:

Full Fine-Tuning on Lightweight LLMs. For the four lightweight LLMs with fewer than 1 billion parameters, i.e., CodeBERT, GraphCodeBERT, CodeT5, and UniXcoder, we utilized full parameter fine-tuning. This approach updates all model parameters to adapt the LLMs to the training data. Full parameter fine-tuning is the standard approach for these lightweight LLMs across various code-related tasks such as code search and defect prediction [27, 34, 35, 79].

Parameter-Efficient Fine-Tuning (PEFT) on Large LLMs. For the eight large LLMs with more than 1 billion parameters such as DeepSeekCoder (DSCoder), we utilized the parameter-efficient fine-tuning technique to adapt them to the training data. This is because full-parameter fine-tuning comes at a significant computational cost when the LLM contains billions of parameters, exceeding our current computational resources [82]. Additionally, recent studies [20, 82] suggest that parameter-efficient tuning techniques can achieve comparable or even better performance on LLMs exceeding 1 billion parameters. Technically, parameter-efficient tuning techniques selectively update a subset of the model's parameters, significantly reducing the computational resources required [20, 40, 57]. In this work, we employ a popular and widely used parameter-efficient tuning technique called LoRA (Low-Rank Adaptation) [40], which has been widely used in many existing studies [22, 53, 77, 82]. LoRA allows the LLM to adapt to the target task while preserving its pre-trained knowledge and reducing the computational requirements compared to full-parameter fine-tuning [82].

3 EXPERIMENTAL SETUP

3.1 Vulnerability Detection Scenarios

Aligned with the previous work [51], we assess the vulnerability detection capabilities of SAST tools and LLMs across two distinct scenarios. Specifically, we investigated:

- **Scenario 1 (S1):** A vulnerability is considered detected if the SAST tool or LLM identifies at least one vulnerable function within the vulnerable repository.
- **Scenario 2 (S2):** A vulnerability is only considered detected if the SAST tool or LLM identifies all vulnerable functions present in the vulnerable repository.

These scenarios underscore the significance of tools capable of pinpointing vulnerabilities within repositories precisely. By accurately identifying the vulnerable functions associated with potential security weaknesses, such tools streamline the manual search and

remediation process for developers, enabling them to concentrate their efforts effectively on the identified vulnerable functions.

3.2 Evaluation Metrics

We follow the previous work [51] to employ the following metrics:

$$\text{Vuln. Detection Ratio} = \frac{\# \text{Detected Vuln.}}{\# \text{All Vuln. in Benchmark}}$$

$$\text{Marked Function Ratio} = \frac{\# \text{Marked Function}}{\# \text{All Functions in Benchmark}}$$

The first metric (i.e., the vulnerability detection ratio) computes the proportion of detected vulnerabilities present in the benchmark. A high vulnerability detection ratio signifies superior performance in vulnerability detection. The second metric (i.e., the marked function ratio) approximates the false positive rate [51] because, on average, only 0.008%–0.18% of functions are vulnerable in the repositories, meaning that the majority of marked functions are non-vulnerable. A low marked function ratio is desirable, as it reduces the number of functions developers need to inspect manually.

We refrain from employing the commonly used evaluation metric Precision in this study, aligning with previous research [51]. This decision stems from the inherent challenges in assessing real-world programs, which may conceal undiscovered vulnerabilities. Our knowledge is confined to vulnerabilities reported or identified by the community. Consequently, we lack precise information on the total number of positive samples (vulnerable functions), encompassing both known and unknown vulnerable functions. Precision requires precise information on all positive samples, rendering its calculation unfeasible in our context. We also cannot compute the F1 score, as it is based on Precision.

3.3 Implementation Details

Data Split. Following the previous work [27, 35, 88], we randomly split each vulnerability dataset into disjoint training, validation, and test sets in a ratio of 8:1:1. The training and validation sets are used to fine-tune/prompt LLMs. Both SAST and LLMs are evaluated on the same test sets for fair comparison.

Implementations. For prompt-based methods, any required labeled data (e.g., for few-shot prompting) is randomly sampled from the training set. In contrast, fine-tuning-based methods employ a different approach. Firstly, we identify and extract all vulnerable functions from the repositories in the training set. Subsequently, we randomly select an equal number of non-vulnerable functions from the repositories in the training set. By combining these two groups of functions, we construct a balanced training set for fine-tuning LLMs. This balancing process is essential for effective model training when dealing with highly imbalanced datasets [38, 83, 84]. Without the balancing, models would be overly biased towards learning the features of non-vulnerable functions due to their dominance in the datasets, resulting in sub-optimal performance in detecting vulnerable samples [86]. Similarly, we also construct a balanced validation set for model validation. Additionally, for LLMs, we develop a generation pipeline in Python, utilizing PyTorch implementations of studied LLMs. We leverage the Hugging Face library [24] to load the model weights and generate outputs. We fine-tune all LLMs for 20 epochs, with a batch size of 8, and select the best model snapshot based on the validation performance. For

Table 3: Experimental results of repo-level vulnerability detection. “S1 D” refers to the vulnerability detection ratio in Scenario 1; “S2 D” refers to the vulnerability detection ratio in Scenario 2; “Marked” refers to the marked function ratio.

Benchmarks			Java			C			Python			
Categories	Method	S1 D↑	S2 D↑	Marked↓	S1 D↑	S2 D↑	Marked↓	S1 D↑	S2 D↑	Marked↓		
SAST	Java	CodeQL	0.0	0.0	0.2	-	-	-	-	-	-	
		Contrast	0.0	0.0	0.0	-	-	-	-	-	-	
		Horusec	7.5	0.0	1.7	-	-	-	-	-	-	
		Insider	0.0	0.0	1.4	-	-	-	-	-	-	
		SpotBugs	0.0	0.0	0.0	-	-	-	-	-	-	
		Semgrep	25.0	.0	2.1	-	-	-	-	-	-	
		SonarQube	0.0	0.0	0.6	-	-	-	-	-	-	
	C	Flawfinder	-	-	-	0.0	0.0	1.9	-	-	-	
		Cppcheck	-	-	-	0.0	0.0	0.3	-	-	-	
		Infer	-	-	-	11.1	11.1	0.9	-	-	-	
		CodeChecker	-	-	-	0.0	0.0	0.3	-	-	-	
		CodeQL	-	-	-	4.4	3.3	5.2	-	-	-	
	Python	Badnit	-	-	-	-	-	-	20.0	0.0	2.4	
		Dlint	-	-	-	-	-	-	20.0	0.0	0.6	
		DevSkim	-	-	-	-	-	-	0.0	0.0	4.5	
		CodeQL	-	-	-	-	-	-	0.0	0.0	0.4	
		Graudit	-	-	-	-	-	-	0.0	0.0	0.04	
		Semgrep	-	-	-	-	-	-	10.0	10.0	0.6	
	LLM	Full Tuning	CodeBERT	87.5	50.0	35.4	100.0	88.9	36.2	80.0	60.0	41.2
			GraphCodeBERT	75.0	50.0	30.1	100.0	88.9	44.6	80.0	70.0	50.0
			CodeT5	87.5	62.5	24.3	88.9	77.8	19.8	90.0	90.0	50.5
			Unixcoder	75.0	62.5	21.4	100.0	88.9	25.6	70.0	50.0	42.0
PEFT		CodeLlama	75.0	37.5	.3	44.4	44.4	7.4	80.0	40.0	39.5	
		Llama3	100.0	87.5	21.8	22.2	22.2	.5	80.0	60.0	29.8	
		CodeQwen	75.0	37.5	14.8	22.2	22.2	12.2	80.0	60.0	35.8	
		DeepSeek-Coder	62.5	62.5	15.1	11.1	11.1	10.6	50.0	30.0	17.3	
		Mistral	62.5	50.0	21.8	11.1	11.1	6.5	50.0	10.0	18.9	
		Phi3	50.0	50.0	20.4	33.3	33.3	10.3	50.0	20.0	20.8	
		Starcoder	75.0	37.5	15.6	44.4	44.4	12.0	50.0	30.0	26.5	
		Starcoder2	87.5	50.0	37.5	0.0	0.0	0.3	40.0	40.0	25.4	
Zero-shot		CodeLlama	87.5	50.0	66.9	44.4	44.4	47.0	70.0	40.0	51.2	
		Llama3	87.5	62.5	47.3	66.7	55.6	49.4	50.0	20.0	40.1	
		CodeQwen	50.0	37.5	60.1	33.3	33.3	53.7	70.0	30.0	51.3	
		DeepSeek-Coder	37.5	12.5	35.4	11.0	0.0	24.3	70.0	40.0	37.1	
		Mistral	50.0	25.0	64.6	55.6	55.6	60.5	80.0	50.0	52.4	
		Phi3	62.5	25.0	41.9	77.8	66.7	66.0	20.0	0.0	30.8	
		Starcoder	62.5	37.5	73.4	66.7	55.6	54.1	50.0	20.0	55.9	
		Starcoder2	37.5	12.5	29.3	44.4	44.4	25.6	20.0	0.0	15.2	
CoT		CodeLlama	75.0	50.0	70.4	55.6	44.4	50.0	60.0	20.0	57.4	
		Llama3	75.0	37.5	47.4	44.4	33.3	46.9	80.0	40.0	42.2	
		CodeQwen	75.0	37.5	66.4	44.4	33.3	53.3	80.0	60.0	51.0	
		DeepSeek-Coder	25.0	25.0	29.2	0.0	0.0	18.0	30.0	0.0	29.6	
		Mistral	62.5	37.5	69.2	77.8	66.7	64.8	70.0	50.0	57.7	
		Phi3	12.5	0.0	44.9	66.7	66.7	64.6	50.0	20.0	32.6	
		Starcoder	87.5	50.0	70.6	55.6	44.4	50.8	60.0	40.0	53.7	
		Starcoder2	75.0	50.0	41.9	55.6	44.4	28.3	40.0	20.0	22.2	
Few-shot		CodeLlama	62.5	37.5	74.7	66.7	55.6	59.2	90.0	70.0	64.3	
		Llama3	62.5	25.0	29.8	44.4	44.4	43.1	70.0	60.0	35.9	
		CodeQwen	50.0	25.0	61.1	55.6	44.1	47.7	70.0	50.0	45.4	
		DeepSeek-Coder	12.5	12.5	26.0	0.0	0.0	5.4	30.0	10.0	4.9	
	Mistral	25.0	12.5	22.0	33.3	22.2	28.7	50.0	20.0	22.4		
	Phi3	75.0	37.5	59.2	44.4	44.4	58.3	40.0	10.0	28.9		
	Starcoder	75.0	50.0	66.8	55.6	55.6	45.3	80.0	50.0	46.7		
	Starcoder2	62.5	37.5	77.4	55.6	55.6	70.1	70.0	60.0	73.4		

the parameter-efficient tuning technique LoRA, we set its parameters as $r = 8$ and $\alpha = 16$. All the experiments are conducted on an Ubuntu 22.04 server equipped with A5000 GPU.

3.4 Research Questions

Our work aims to answer three research questions (RQs).

- **RQ1: How effective are SAST tools and LLMs?** In RQ1, we evaluate a comprehensive list of 15 SAST tools and 12 LLMs in their ability to detect vulnerabilities in software repositories.
- **RQ2: Which one is more effective for detecting vulnerabilities, SAST tools or LLMs?** In RQ2, we compare the effectiveness of SAST tools against LLMs, aiming to determine which approach performs better in detecting vulnerabilities across different programming languages.
- **RQ3: To what extent can combining multiple SAST tools or LLMs improve vulnerability detection?** In RQ3, we investigate the potential enhancements in vulnerability detection achieved by integrating multiple SAST tools and LLMs.

4 EXPERIMENTAL RESULTS

4.1 RQ1: Effectiveness of SAST Tools and LLMs

Table 3 displays the experimental results, encompassing metrics such as “S1 D,” “S2 D,” and “Marked.” The “S1 D” metric refers to the ratio of detected vulnerabilities in Scenario 1, where detection is considered successful upon identifying any vulnerable function within the vulnerable repository. The “S2 D” metric represents the detection ratio in Scenario 2, where a vulnerability is considered as detected only when all vulnerable functions in the repository are identified. The “Marked” metric indicates the percentage of functions labeled as vulnerable. A higher detection ratio signifies superior performance in vulnerability detection, whereas a lower marked function ratio is preferred, as it reduces the number of functions developers need to check to locate the actual vulnerabilities. In Table 3, bold numbers with green cells indicate the best performance, and underlined numbers with light green cells indicate the second-best performance. Please note that for the best marked function ratio, we consider the tool or model that achieves the lowest marked function ratio while still detecting at least one vulnerability. A tool or model that fails to detect any vulnerabilities, regardless of its marked function ratio, is not considered to have the best marked function ratio.

4.1.1 Effectiveness of SAST Tools. SAST tools achieved low detection rates. Many SAST tools, such as CodeQT, Contrast, Insider, SpotBugs, SonarQube for Java, FlawFinder, CppChecker, and CodeChecker for C, and CodeQL and Graudit for Python, failed to detect vulnerabilities. Among SAST tools, Horusec performed the best for Java, achieving a 37.5% detection rate in Scenario 1. For C, CodeQL exhibited the best performance, attaining detection rates of 44.4% and 33.3% in Scenario 1 and 2. For Python, DevSkim performed the best with detection rates of 30.0% and 20.0% in Scenario 1 and 2. **The advantage of SAST tools is they marked a small percentage of functions as vulnerable.** Low marked function ratios could facilitate developers in identifying the actual vulnerability location by inspecting fewer marked functions. SAST tools marked only 0.2% to 5.2% of all functions on average.

4.1.2 Effectiveness of LLMs. LLMs achieved high detection rates. For Java, many LLMs exhibited detection rates ranging from over 50% to as high as 100% in Scenario 1, and from surpassing 37.5% to as high as 87.5% in Scenario 2. Similarly, for C, LLMs achieved detection rates up to 100.0% and 88.9% in Scenario 1 and Scenario 2. For Python, LLMs achieved detection rates up to 90.0% in both Scenario 1 and Scenario 2. **However, the drawback of LLMs is they mark a large portion of functions as vulnerable.** This indicates that their high detection rates come at the cost of marking many functions in the repository as suspicious. Consequently, this makes it difficult for developers to pinpoint the actual vulnerability locations, as they need to inspect a large number of marked functions. Specifically, LLMs mark 8.3% to 77.4% of functions in Java, 3.5% to 70.1% in C, and 14.9% to 73.4% in Python.

4.1.3 Comparisons Among LLMs. Among different adaptations for large LLMs ($\geq 1B$), fine-tuning achieves the highest detection ratios with the fewest marked vulnerable functions. For instance, in Java, the fine-tuned large LLMs detect an average of 73.4% and 51.6% of vulnerabilities in S1 and S2 respectively, across different LLM models. This outperforms the prompt-based methods by 20.5% to 73.7% in terms of average detection ratios. Meanwhile, the fine-tuned large LLMs mark only 19.4% of functions as vulnerable on average, which is much less than the prompt-based methods, ranging from 52.1% to 55.0%. Thus, fine-tuned large LLMs outperform prompted large LLMs. **Fine-tuned lightweight LLMs detect more vulnerabilities but also mark more functions as vulnerable compared to fine-tuned large LLMs.** For example, in Java, fine-tuned lightweight LLMs outperform the fine-tuned large LLMs by 10.6% and 9.1% in S1 and S2, on average. However, at the same time, fine-tuned lightweight LLMs mark 43.2% more functions as vulnerable on average.

Answer to RQ1: SAST tools obtained lower vulnerability detection rates (up to 44.4%) while also marking fewer functions as vulnerable (up to 5.2%). In contrast, LLMs detected more vulnerabilities (up to 100%) but also marked a higher proportion of functions as vulnerable (up to 77.4%).

4.2 RQ2: SAST Tools vs. LLMs

4.2.1 Comprehensive Comparison between SAST and LLMs. The advantages and disadvantages of SAST tools and LLMs are evident: 1) SAST tools mark fewer functions but detect fewer vulnerabilities, while 2) LLMs detect more vulnerabilities but require marking substantially more functions. There seems to be a trade-off between detection ratios and marked function ratios: the more vulnerabilities detected, the greater the number of functions marked as potentially vulnerable. Thus, our aim here is to identify the optimal SAST tools and LLMs that reach a sweet spot in the trade-off between detection ratios and marked function ratios, optimizing both metrics for practical vulnerability detection scenarios.

To comprehensively understand the capabilities of SAST tools and LLMs, we plot the relationships between detection ratios (Scenario 2) and marked function ratios in Figure 3. The optimal tools/models are those capable of detecting more vulnerabilities with fewer marked functions, typically occupying the upper-left areas of Figure 3. In Figure 3, we exclude prompt-based large LLMs because

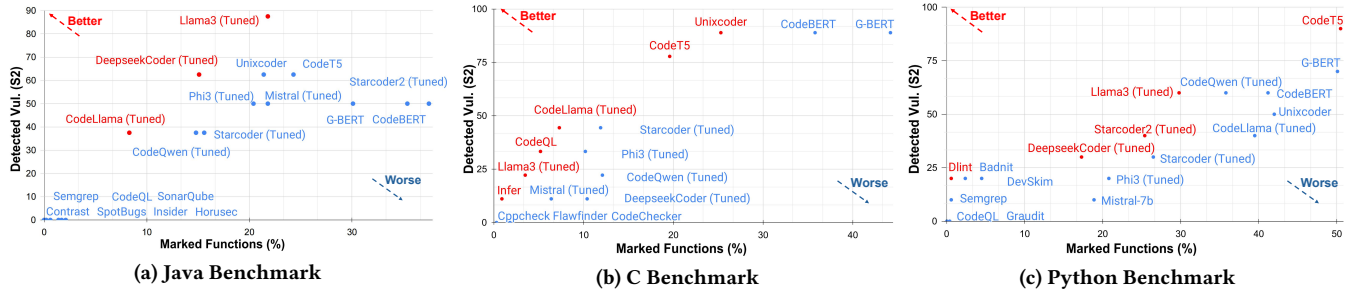


Figure 3: The Relationship between the Vulnerability Detection Ratios (Scenario 2) and the Marked Function Ratios

they usually appear in the bottom-right area (low detection ratios with high marked function ratios).

We highlight the tools/models in red in the upper-right area of the figures, indicating those are more optimal when comprehensively considering both metrics. **Our analysis reveals that the optimal approaches differ across programming languages.** For instance, fine-tuned CodeLlama, fine-tuned DeepSeekCoder, and fine-tuned Llama3 emerge as the optimal choices for Java. Similarly, for C, the optimal models/tools include Infer, fine-tuned Llama3, CodeQL, fine-tuned CodeLlama, CodeT5, and UnixCoder. For Python, the optimal tools/models are Dlint, fine-tuned DeepSeekCoder, fine-tuned StarCoder2, fine-tuned Llama3, and CodeT5. **The best choice will depend on the user's acceptance of the trade-off between detection ratios and marked function ratios.** For instance, for Java, if a user requires a model/tool with at most a 10% marked function ratio, the fine-tuned CodeLlama would be the best choice.

To identify the best approach objectively, we also propose a ranking-based metric: 1) We rank each approach based on two criteria: the detection ratio in S2 and the marked function ratio. 2) We then sum the ranks of two criteria. The approach with the lowest total rank is considered the best. According to this ranking-based metric, **fine-tuned DeepseekCoder, UniXcoder, and Llama3 are the best approaches for Java, C, and Python, respectively.**

4.2.2 Best vs. Worst Detected Vulnerabilities. We studied the detection rates of vulnerabilities belonging to different vulnerability classes. Due to the page limit, we simplify the analysis by merging the results corresponding to the three programming languages together. Additionally, we consider the combined results of SAST tools: a vulnerability is considered detected if at least one SAST tool can detect it. Similarly, we consider the combined results of the 2 optimal LLMs. Specifically, we focus on the 2 optimal models highlighted in Figure 3, which have the lowest marked function ratios. For Java, the 2 optimal LLMs are fine-tuned CodeLlama and DeepSeekCoder. For C, the 2 optimal LLMs are fine-tuned Llama3 and CodeLlama. For Python, the optimal LLMs are fine-tuned DeepSeekCoder and StarCoder2. A vulnerability is considered detected if at least one of the 2 optimal LLMs can detect it.

Figure 4 illustrates the detection rates of vulnerability classes that are best and worst detected by SAST tools and the 2 optimal LLMs. The most frequently detected vulnerability class in Scenarios 1 and 2 is CWE-119. Notably, the LLM group can achieve 100% detection rates for CWE-119. Additionally, CWE-476 is the second-best detected vulnerability class by both the SAST group and the LLM group. In contrast, CWE-835 and CWE-89 are the worst detected

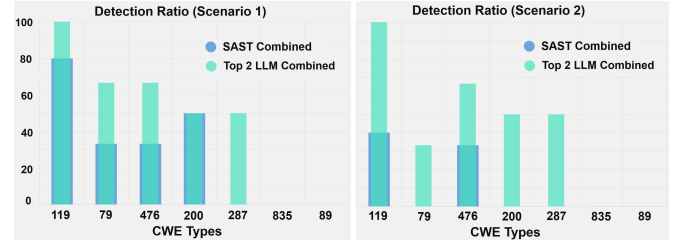


Figure 4: Vulnerability Detection Ratios in Different Classes. Both the SAST tool group and the 2 optimal LLMs group failed to detect any vulnerabilities in these classes.

Answer to RQ2: The choice of the best approach depends on the programming language. Fine-tuned DeepseekCoder, UniXcoder, and Llama3 are the best approaches for Java, C, and Python, respectively.

4.3 RQ3: Combining SAST Tools or LLMs

4.3.1 Combining SAST Tools. The main limitation of SAST tools is their low detection ratios. Thus, the goal of combining SAST tools is to improve the detection ratios, even if it comes at the cost of higher marked function ratios. To achieve this goal, we employ the following combining strategy to fuse the predictions of SAST tools: if a function is marked as vulnerable by any of the SAST tools, the function is considered to be marked as vulnerable by the SAST combination. The first two columns of Figures 5–7 show the detection ratios and marked ratios of the individual SAST tool with the highest detection ratio, as well as the combination of all SAST tools, for Java, C, and Python, respectively. **The results demonstrate that combining all SAST tools substantially boosts detection ratios, ranging from 25.2% to 100.0%.** For Java, the detection ratio in Scenario 1 improved from 37.5% to 50.0%, at the cost of increasing the marked function ratio from 1.7% to 4.3%. For C, the detection ratios improved from 44.4% to 55.6% in Scenario 1 and from 33.3% to 44.4% in Scenario 2, at the cost of increasing the marked function ratio from 5.2% to 7.2%. For Python, the detection ratios improved from 30.0% to 50.0% in S1 and from 20.0% to 40.0% in S2, with an increase in the marked functions from 4.5% to 7.7%.

4.3.2 Combining LLMs. Different from SAST tools, the main limitation of LLMs is their high marked function ratios. Thus, the goal of combining LLM models is to reduce the marked function ratios, even if it comes at the cost of sacrificing some detection ratios. Specifically, we include 12 LLMs in the LLM combination: four fine-tuned lightweight LLMs and eight fine-tuned large LLMs. Regarding the combination strategies, we aim to reduce the number

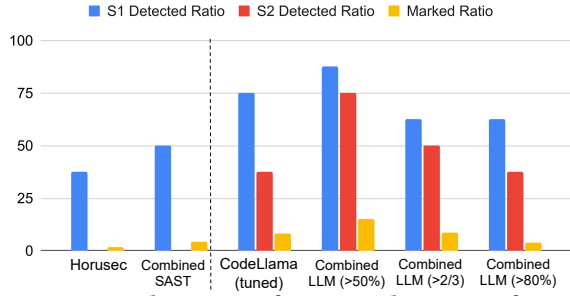


Figure 5: Combinations of SAST Tools or LLMs for Java

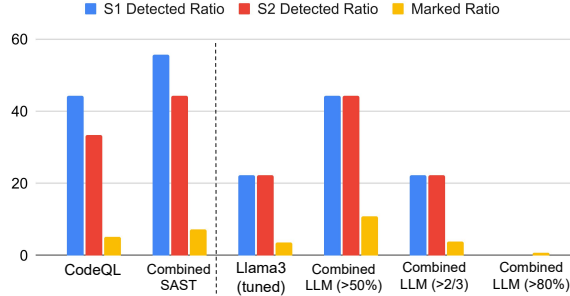


Figure 6: Combinations of SAST Tools or LLMs for C

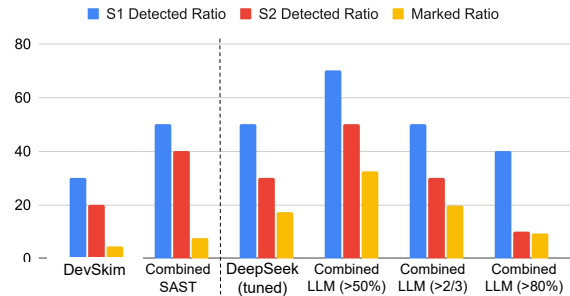


Figure 7: Combinations of SAST Tools or LLMs for Python

of marked functions. Thus, we employ three voting mechanisms on the predictions of 12 fine-tuned LLMs: **1) C1 (voting>50%)**: if more than half of the LLMs agree to mark one function as vulnerable, the combination of LLMs will mark the function as vulnerable; **2) C2 (voting> $\frac{2}{3}$)**: if more than $\frac{2}{3}$ of LLMs agree to mark one function as vulnerable, the combination of LLMs will mark the function as vulnerable; **3) C3 (voting>80%)**: if more than 80% of LLMs agree to mark one function as vulnerable, the combination of LLMs will mark the function as vulnerable.

The last four columns of Figures 5–7 present the detection ratios and marked function ratios for one of the best individual LLMs (as determined from Figure 3), as well as for three different combinations of multiple LLM models for Java, C, and Python. **The results show that combining multiple LLMs can substantially reduce the marked function ratios compared to individual LLMs on average.** For instance, in the C2 LLM combination, it could reduce the marked function ratios by 61.7%, 74.6%, and 40.9% in the Java, C, and Python benchmarks, respectively, compared to the average marked function ratios of the 12 fine-tuned LLMs. Additionally, the C2 LLM combination could achieve comparable detection ratios to the best-performing single LLM in each programming language

(fine-tuned CodeLlama for Java, fine-tuned Llama3 for C, and fine-tuned DeepSeekCoder for Python), indicating that the detection ratios are not significantly compromised in this C2 combination. **The more models we require LLMs to agree on the vulnerable predictions, the lower detection ratio and marked function ratios we can obtain.** For instance, when requiring agreement from more than 80% of LLMs for a vulnerable prediction, the marked function ratios become comparable to those of SAST tools (0.8%–9.2%). However, this stringent agreement criterion leads to poor detection ratios, reaching only 0%–37.5% in Scenario 2.

4.3.3 Combined SAST v.s. Combined LLMs. We discuss which combination strategy is better for each programming language. **For Java, the C3 LLM combination is better** than the SAST combination because it has higher detection ratios and comparable marked function ratios. **For C, the SAST combination is better** because it has higher detection ratios and a lower marked function ratio compared to the C1 LLM combination. In addition, the SAST combination obtains substantially higher detection ratios with an acceptable increase in marked function ratios compared to the C2 and C3 LLM combinations. **For Python, the SAST combination is better.** Compared to the C2 and C3 LLM combinations, the SAST combination has comparable detection ratios with a much lower marked function ratio. Moreover, the marked function ratio of the C1 LLM combination is unacceptably high (i.e., 32.6%), making it an unfavorable choice.

Answer to RQ3: Combining SAST tools substantially boosts detection ratios, ranging from 25.2% to 100.0%. Combining LLMs substantially reduces the marked function ratio by 40.9%–74.6% on average. The optimal approach differs across programming languages. For Java, the LLM combination provides the most effective solution, while for C and Python, the combination of SAST tools is better.

5 DISCUSSION

5.1 Evaluating Commercial LLM ChatGPT

In this work, we focus on open-source LLMs because using commercial LLMs for this task would be very costly, considering the large number of functions in each repository. However, to make our paper more self-contained, we also conducted small-scale experiments with the famous commercial LLM ChatGPT. Specifically, we set the ratio of vulnerable functions to clean functions as 1:100 and sampled the corresponding number of clean functions from the repository. We used the *gpt-3.5-turbo-0125* model [66], the latest version of GPT-3.5, and set the temperature to 0 for more reproducible results. Table 4 presents the results of ChatGPT and two open-source LLMs, Llama3 and CodeBERT, with the same setting, averaged across Java, C, and Python. In general, the results show that the commercial LLM ChatGPT achieved lower vulnerability detection ratios and marked fewer functions as potentially vulnerable compared to the open-source LLMs such as Llama3 and CodeBERT. Among different ways of using ChatGPT, the few-shot prompting detects most vulnerabilities (i.e., 23.2%).

5.2 Implications

Repo-level vulnerability detection using LLMs holds substantial potential. While LLMs may not yet outperform SAST tools in

Table 4: Evaluating ChatGPT on A Small Detection Range.

Pos:Neg =1:100	CodeBERT (Tuned)	Llama3 (Tuned)	GPT3.5 (Zero-shot)	GPT3.5 (CoT)	GPT3.5 (Few-shot)
S1 D ↑	89.2	67.4	3.7	3.7	23.2
S2 D ↑	66.3	56.6	3.7	3.7	11.1
Marked ↓	35.7	20.1	1.3	2.1	10.8

every facet, as the first work exploring this direction, we have employed generic LLM techniques without incorporating specialized designs to maximize their effectiveness. However, we have still observed that LLMs can achieve competitive performance compared to SAST tools, particularly when looking into individual SAST tools and LLMs. This underscores the significant potential for advancing repo-level vulnerability detection through further development and refinement of LLM-based approaches.

Repo-level vulnerability detection is more practical than the function-level vulnerability detection. We recommend a gradual shift in vulnerability detection efforts from the existing function-level task formation to the repo-level vulnerability detection task formation introduced in this study. As shown in Figure 2, datasets used in traditional function-level vulnerability detection studies rely on vulnerability-fixing commits to narrow the detection scope from the entire repository to the specific files modified in those commits. However, when the goal is to detect vulnerabilities, the corresponding vulnerability-fixing commit does not yet exist. Consequently, it is impractical to depend on such commits to limit the detection range. The repo-level vulnerability detection formation addresses this issue by eliminating the need to narrow down the detection scope based on the fixing commits.

Addressing the high marked function ratios of LLMs necessitates further investigation. While LLMs tend to detect more vulnerabilities compared to SAST tools, they suffer from high marked function ratios, akin to high false positive rates. Although we managed to significantly reduce these ratios by combining multiple LLMs, there remains large room for enhancement. Potential solutions may entail developing techniques such as, filtering out less trustworthy predictions from LLMs, integrating additional contextual information (e.e., the structural features in the repository) with LLMs, refining prompting strategies, or employing more advanced ensemble methods.

Exploring advanced combinations of LLMs and SAST tools holds promise. Each category of approach has its strengths and weaknesses in detecting vulnerabilities in software repositories: LLMs detect more vulnerabilities but with higher marked function ratios, whereas SAST tools detect fewer vulnerabilities but with lower marked function ratios. Future research could propose methods that can effectively leverage the strengths of both approaches for enhanced vulnerability detection.

5.3 Threats to Validity

Threats to internal validity relate to possible errors and biases in our experiments. To mitigate these risks, we utilized the official implementations of the studied tools and models to ensure correctness. We have reviewed and validated our code and data, and they are publicly accessible to promote transparency and reproducibility. Another potential threat concerns the presence of undetected vulnerabilities in the vulnerability benchmarks. However, our objective was to assess whether the selected tools/models could accurately

identify known vulnerabilities. Thus, it is reasonable to draw conclusions about the effectiveness of these tools/models in detecting known vulnerabilities. Additionally, the potential for data leakage poses another threat, where LLMs might have been exposed to our evaluation datasets during their pre-training. This risk of data leakage is a widespread issue that affects numerous works related to LLMs (e.g., [2, 31]). Unfortunately, directly addressing this concern is almost impossible due to the non-public nature of pre-training datasets used by LLMs, especially commercial models like ChatGPT. Nevertheless, we observed that, compared to fine-tuning, LLMs do not perform effectively under zero-shot, chain-of-thought, and few-shot prompting. This suggests that memorization may not be a significant factor; if the models had already been pre-trained on our evaluation datasets, they would have achieved significantly better performance with the prompts, even without fine-tuning on our training sets. Threats to external validity relate to the generalizability of our findings. To mitigate this potential concern, we employed a comprehensive list of 15 static analysis security testing tools and 12 popular or state-of-the-art large language models in this study. Additionally, we utilized experimental datasets spanning three popular programming languages: Java, C, and Python. Our extensive and diverse experiments help to alleviate concerns regarding the generalizability of our findings.

6 RELATED WORK

Studies of SAST Tools. There are many existing studies evaluating static analysis security testing (SAST) tools, e.g., [5, 8, 10, 13, 26, 32, 32, 36, 45, 46, 46, 48, 49, 51, 52, 61, 63, 68, 74, 76]. Some of these studies utilize synthetic benchmarks to evaluate SAST tools, e.g., [5, 8, 48]. Several studies have evaluated SAST tools on real-world vulnerability datasets in C/C++ or Java [32, 46, 49, 51, 74]. For instance, Lipp et al. [51] focused on SAST tools for C programs, evaluating the effectiveness of six tools on real-world vulnerability datasets. Li et al. [49] evaluated the effectiveness of seven free or open-source SAST tools on real-world vulnerability datasets. Several studies have evaluated SAST tools in other research areas, such as Android [13, 26, 68].

Our work distinguishes itself from existing studies in the following aspects. Firstly, we evaluated SAST tools and LLM models on three popular programming languages: Java, C, and Python. This ensures diversity in the experimental datasets, unlike many previous studies that focused on a single programming language. Secondly, to the best of our knowledge, we are the first to evaluate SAST tools for Python vulnerability detection. Thirdly, we are the first to comprehensively compare SAST tools with LLMs, which have demonstrated strong effectiveness in many other code-related tasks such as code generation [54] and automated repair [44].

LLM-based Vulnerability Detection. There are many existing studies utilizing large language models (LLMs) for vulnerability detection, e.g., [27, 30, 35, 37, 55, 67, 84, 85, 87]. For instance, Liu et al. [55] leveraged the abstract syntax tree and program dependence graph of functions to pre-train their LLM. The pre-training process enabled the LLM to predict dependencies within the functions effectively. Peng et al. [67] employed program slicing, a technique that extracts control and data dependency information, to enhance the capability of LLMs in vulnerability detection. Additionally, Zhang

et al. [85] proposed an approach that involved decomposing syntax-based control flow graphs into multiple execution paths. These execution paths were then fed as input to LLMs for enhancement. Recently, a parallel work [81] proposed an approach to enhance the function-level vulnerability detection task by retrieving relevant dependencies from the repository. Specifically, their approach involves concatenating the target functions (those in files changed by vulnerability-fixing commits) with the relevant dependencies retrieved from the repository. In contrast to their work, our work aims to assess and compare the effectiveness of SAST tools and LLMs in detecting vulnerabilities from entire repositories rather than from files changed by the fixing commits.

While numerous studies have explored the use of LLMs for vulnerability detection, they have focused on identifying vulnerabilities within individual functions. In addition, existing works have not comprehensively compared their approaches with diverse SAST tools, and they have typically focused on one programming language. Our research diverges from previous works by (1) evaluating the efficacy of LLMs in detecting vulnerabilities from entire repositories (repo-level vulnerability detection), and (2) evaluating their efficacy against a comprehensive list of 15 SAST tools, spanning three widely-used programming languages: Java, C, and Python.

7 CONCLUSION AND FUTURE WORK

In this study, we compare the efficacy of 15 diverse SAST tools alongside 12 popular or leading LLMs. Our experiments focus on real-world vulnerabilities across three prevalent programming languages: Java, C, and Python. Our findings indicate that SAST tools exhibit low vulnerability detection ratios while maintaining a low marked function ratio, akin to a low false positive rate. In contrast, LLMs demonstrate high vulnerability detection ratios but are accompanied by elevated marked function ratios (akin to high false positive rates). Through ensemble approaches, we demonstrate that combining SAST tools and LLMs mitigates their respective limitations, resulting in improved overall vulnerability detection performance.

In the future, we aim to investigate more sophisticated methods for effectively combining multiple LLMs and SAST tools to further improve vulnerability detection performance.

REFERENCES

- [1] 2023. *Tree-sitter*. <https://tree-sitter.github.io/tree-sitter/>
- [2] Toufique Ahmed, Kunal Suresh Pai, Premkumar Devanbu, and Earl Barr. 2024. Automatic semantic augmentation of language model prompts (for code summarization). In *Proceedings of the IEEE/ACM 46th International Conference on Software Engineering*. 1–13.
- [3] Mistral AI. 2023. Mistral. <https://huggingface.co/mistralai/Mistral-7B-v0.1>
- [4] Bushra Aloraini, Meiyappan Nagappan, Daniel M German, Shinpei Hayashi, and Yoshiki Higo. 2019. An empirical study of security warnings from static application security testing tools. *Journal of Systems and Software* 158 (2019), 110427.
- [5] Midya Alqaradaghi, Gregory Morse, and Tamás Kozsik. 2021. Detecting security vulnerabilities with static analysis—A case study. *Pollack Periodica* (2021).
- [6] Jinze Bai, Shuai Bai, Yunfei Chu, Zeyu Cui, Kai Dang, Xiaodong Deng, Yang Fan, Wenbin Ge, Yu Han, Fei Huang, Binyuan Hui, Luo Ji, Mei Li, Junyang Lin, Runji Lin, Dayiheng Liu, Gao Liu, Chengqiang Lu, Keming Lu, Jianxin Ma, Rui Men, Xingzhang Ren, Xuancheng Zhang, Yichang Zhang, Zhenru Zhang, Chang Zhou, Jingren Zhou, Xiaohuan Zhou, and Tianhang Zhu. 2023. Qwen Technical Report. *arXiv preprint arXiv:2309.16609* (2023).
- [7] Bandit. null. Bandit: a tool designed to find common security issues in Python code. <https://github.com/PyCQA/bandit>
- [8] Sindre Beba and Magnus Melseth Karlsen. 2019. *Implementation analysis of open-source Static analysis tools for detecting security vulnerabilities*. Master's thesis. NTNU.
- [9] Guru Bhandari, Amara Naseer, and Leon Moonen. 2021. CVEfixes: automated collection of vulnerabilities and their fixes from open-source software. In *Proceedings of the 17th International Conference on Predictive Models and Data Analytics in Software Engineering*. 30–39.
- [10] Tiago Brito, Mafalda Ferreira, Miguel Monteiro, Pedro Lopes, Miguel Barros, José Fragoso Santos, and Nuno Santos. 2023. Study of JavaScript Static Analysis Tools for Vulnerability Detection in Node.js Packages. *IEEE Transactions on Reliability* (2023).
- [11] Tom Brown, Benjamin Mann, Nick Ryder, Melanie Subbiah, Jared D Kaplan, Prafulla Dhariwal, Arvind Neelakantan, Pranav Shyam, Girish Sastry, Amanda Askell, et al. 2020. Language models are few-shot learners. *Advances in neural information processing systems* 33 (2020), 1877–1901.
- [12] Saikat Chakraborty, Rahul Krishna, Yangruibo Ding, and Baishakhi Ray. 2021. Deep learning based vulnerability detection: Are we there yet? *IEEE Transactions on Software Engineering* 48, 9 (2021), 3280–3296.
- [13] Sen Chen, Lingling Fan, Guozhu Meng, Ting Su, Minhui Xue, Yinxing Xue, Yang Liu, and Lihua Xu. 2020. An empirical assessment of security risks of global android banking apps. In *Proceedings of the ACM/IEEE 42nd International Conference on Software Engineering*. 1310–1322.
- [14] Yizheng Chen, Zhoujie Ding, Lanya ALOWAIN, Xinyun Chen, and David Wagner. 2023. Diversevul: A new vulnerable source code dataset for deep learning based vulnerability detection. In *Proceedings of the 26th International Symposium on Research in Attacks, Intrusions and Defenses*. 654–668.
- [15] CodeChecker. null. CodeChecker. <https://codechecker.readthedocs.io/en/latest/>
- [16] CodeQL. null. CodeQL for Research. <https://securitylab.github.com/tools/codeql/>
- [17] Cppcheck. null. A Tool for Static C/C++ Code Analysis. <http://cppcheck.sourceforge.net/>
- [18] Roland Croft, Dominic Newlands, Ziyu Chen, and M Ali Babar. 2021. An empirical study of rule-based and learning-based approaches for static application security testing. In *Proceedings of the 15th ACM/IEEE international symposium on empirical software engineering and measurement (ESEM)*. 1–12.
- [19] Dejian Yang, Zhenda Xie, Kai Dong, Wentao Zhang, Guanting Chen, Xiao Bi, Y. Wu, Y. K. Li, Fuli Luo, Yingfei Xiong, Wenfeng Liang, Daya Guo, Qihao Zhu. 2024. DeepSeek-Coder: When the Large Language Model Meets Programming – The Rise of Code Intelligence. <https://arxiv.org/abs/2401.14196>
- [20] Tim Dettmers, Artidoro Pagnoni, Ari Holtzman, and Luke Zettlemoyer. 2023. Qlora: Efficient finetuning of quantized llms. *arXiv preprint arXiv:2305.14314* (2023).
- [21] DevSkim. null. DevSkim. <https://github.com/microsoft/DevSkim>
- [22] Ning Ding, Yujia Qin, Guang Yang, Fuchao Wei, Zonghan Yang, Yusheng Su, Shengding Hu, Yulin Chen, Chi-Min Chan, Weize Chen, et al. 2022. Delta tuning: A comprehensive study of parameter efficient methods for pre-trained language models. *arXiv preprint arXiv:2203.06904* (2022).
- [23] Dlint. null. Dlint: a tool for encouraging best coding practices and helping ensure Python code is secure. <https://github.com/dlint-py/dlint>
- [24] Hugging Face. 2024. Hugging Face Transformers library. <https://huggingface.co/docs/transformers/index>
- [25] Jiahao Fan, Yi Li, Shaohua Wang, and Tien N Nguyen. 2020. AC/C++ code vulnerability dataset with code changes and CVE summaries. In *Proceedings of the 17th International Conference on Mining Software Repositories*. 508–512.
- [26] Lingling Fan, Ting Su, Sen Chen, Guozhu Meng, Yang Liu, Lihua Xu, Geguang Pu, and Zhendong Su. 2018. Large-scale analysis of framework-specific exceptions in android apps. In *Proceedings of the 40th International Conference on Software Engineering*. 408–419.
- [27] Zhangyin Feng, Daya Guo, Duyu Tang, Nan Duan, Xiaocheng Feng, Ming Gong, Linjun Shou, Bing Qin, Ting Liu, Daxin Jiang, and Ming Zhou. 2020. CodeBERT: A Pre-Trained Model for Programming and Natural Languages. In *Findings of the Association for Computational Linguistics: EMNLP 2020, Online Event, 16–20 November 2020 (Findings of ACL, Vol. EMNLP 2020)*, Trevor Cohn, Yulan He, and Yang Liu (Eds.). Association for Computational Linguistics, 1536–1547.
- [28] Flawfinder. null. Flawfinder. <https://dwteller.com/flawfinder/>
- [29] Michael Fu and Chakkrit Tantithamthavorn. 2022. LineVul: A Transformer-based Line-Level Vulnerability Prediction. In *MSR*. ACM, 608–620.
- [30] Michael Fu, Chakkrit Tantithamthavorn, Van Nguyen, and Trung Le. 2023. Chatgpt for vulnerability detection, classification, and repair: How far are we? *APSEC* (2023).
- [31] Mingyang Geng, Shangwen Wang, Dezun Dong, Haotian Wang, Ge Li, Zhi Jin, Xiaoguang Mao, and Xiangke Liao. 2024. Large language models are few-shot summarizers: Multi-intent comment generation via in-context learning. In *Proceedings of the 46th IEEE/ACM International Conference on Software Engineering*. 1–13.
- [32] Katerina Goseva-Popstojanova and Andrei Perhinschi. 2015. On the capability of static code analysis to detect security vulnerabilities. *Information and Software Technology* 68 (2015), 18–33.

- [33] Graudit. null. Graudit: source code auditing tool. <https://github.com/wireghoul/graudit>
- [34] Daya Guo, Shuai Lu, Nan Duan, Yanlin Wang, Ming Zhou, and Jian Yin. 2022. Unixcoder: Unified cross-modal pre-training for code representation. *arXiv preprint arXiv:2203.03850* (2022).
- [35] Daya Guo, Shuo Ren, Shuai Lu, Zhangyin Feng, Duyu Tang, Shujie Liu, Long Zhou, Nan Duan, Alexey Svyatkovskiy, Shengyu Fu, et al. 2020. Graphcodebert: Pre-training code representations with data flow. *arXiv preprint arXiv:2009.08366* (2020).
- [36] Andrew Habib and Michael Pradel. 2018. How many of all bugs do we find? a study of static bug detectors. In *Proceedings of the 33rd ACM/IEEE International Conference on Automated Software Engineering*. 317–328.
- [37] Hazim Hanif and Sergio Maffei. 2022. VulBERTa: Simplified Source Code Pre-Training for Vulnerability Detection. In *International Joint Conference on Neural Networks, IJCNN 2022, Padua, Italy, July 18-23, 2022*. IEEE, 1–8. <https://doi.org/10.1109/IJCNN55064.2022.9892280>
- [38] Thong Hoang, Hoa Khanh Dam, Yasutaka Kamei, David Lo, and Naoyasu Ubayashi. 2019. Deepjit: an end-to-end deep learning framework for just-in-time defect prediction. In *2019 IEEE/ACM 16th International Conference on Mining Software Repositories (MSR)*. IEEE, 34–45.
- [39] Xinyi Hou, Yanjie Zhao, Yue Liu, Zhou Yang, Kailong Wang, Li Li, Xiapu Luo, David Lo, John Grundy, and Haoyu Wang. 2024. Large Language Models for Software Engineering: A Systematic Literature Review. [arXiv:2308.10620](https://arxiv.org/abs/2308.10620) [cs.SE]
- [40] Edward J Hu, Yelong Shen, Phillip Wallis, Zeyuan Allen-Zhu, Yuanzhi Li, Shean Wang, Lu Wang, and Weizhu Chen. 2021. Lora: Low-rank adaptation of large language models. *arXiv preprint arXiv:2106.09685* (2021).
- [41] Huggingface. 2024. Huggingface Open LLM Leaderboard. https://huggingface.co/spaces/open-llm-leaderboard/open_llm_leaderboard
- [42] Infer. null. A Tool to Detect Bugs in Java and C/C++/Objective-c Code. <https://fbinfer.com/>
- [43] Insidersec. 2022. Insider. <https://github.com/insidersec/insider/>
- [44] Nan Jiang, Kevin Liu, Thibaud Lutellier, and Lin Tan. 2023. Impact of code language models on automated program repair. In *2023 IEEE/ACM 45th International Conference on Software Engineering (ICSE)*. IEEE, 1430–1442.
- [45] Hong Jin Kang, Khai Loong Aw, and David Lo. 2022. Detecting false alarms from automatic static analysis tools: How far are we? In *Proceedings of the 44th International Conference on Software Engineering*. 698–709.
- [46] Arvinder Kaur and Ruchika Nayyar. 2020. A comparative study of static code analysis tools for vulnerability detection in c/c++ and java source code. *Procedia Computer Science* 171 (2020), 2023–2029.
- [47] Takeshi Kojima, Shixiang Shane Gu, Machel Reid, Yutaka Matsuo, and Yusuke Iwasawa. 2022. Large language models are zero-shot reasoners. *Advances in neural information processing systems* 35 (2022), 22199–22213.
- [48] Jingyue Li, Sindre Beba, and Magnus Melseth Karlsen. 2019. Evaluation of open-source IDE plugins for detecting security vulnerabilities. In *Proceedings of the 23rd International Conference on Evaluation and Assessment in Software Engineering*. 200–209.
- [49] Kaixuan Li, Sen Chen, Lingling Fan, Ruitao Feng, Han Liu, Chengwei Liu, Yang Liu, and Yixiang Chen. 2023. Comparison and Evaluation on Static Application Security Testing (SAST) Tools for Java. In *Proceedings of the 31st ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering*. 921–933.
- [50] Raymond Li, Loubna Ben Allal, Yangtian Zi, Niklas Muennighoff, Denis Kocetkov, Chenghao Mou, Marc Marone, Christopher Akiki, Jia Li, Jenny Chim, Qian Liu, Evgenii Zheltonozhskii, Terry Yue Zhuo, Thomas Wang, Olivier Dehaene, Mishig Davaadorj, Joel Lamy-Poirier, João Monteiro, Oleh Shliazhko, Nicolas Gontier, Nicholas Meade, Armel Zebaze, Ming-Ho Yee, Logesh Kumar Umapathi, Jian Zhu, Benjamin Lipkin, Muhtasham Oblokulov, Zhiruo Wang, Rudra Murthy, Jason Stiller, Siva Sankalp Patel, Dmitry Abulkhanov, Marco Zocca, Manan Dey, Zhihan Zhang, Nour Fahmy, Urvashi Bhattacharyya, Wenhao Yu, Swayam Singh, Sasha Luccioni, Paulo Villegas, Maxim Kunakov, Fedor Zhdanov, Manuel Romero, Tony Lee, Nadav Timor, Jennifer Ding, Claire Schlesinger, Hailey Schoelkopf, Jan Ebert, Tri Dao, Mayank Mishra, Alex Gu, Jennifer Robinson, Carolyn Jane Anderson, Brendan Dolan-Gavitt, Danish Contractor, Siva Reddy, Daniel Fried, Dzmitry Bahdanau, Yacine Jernite, Carlos Muñoz Ferrandis, Sean Hughes, Thomas Wolf, Arjun Guha, Leandro von Werra, and Harm de Vries. 2023. StarCoder: may the source be with you! (2023). [arXiv:2305.06161](https://arxiv.org/abs/2305.06161) [cs.CL]
- [51] Stephan Lipp, Sebastian Banescu, and Alexander Pretschner. 2022. An empirical study on the effectiveness of static C code analyzers for vulnerability detection. In *Proceedings of the 31st ACM SIGSOFT International Symposium on Software Testing and Analysis*. 544–555.
- [52] Han Liu, Sen Chen, Ruitao Feng, Chengwei Liu, Kaixuan Li, Zhengzi Xu, Liming Nie, Yang Liu, and Yixiang Chen. 2023. A comprehensive study on quality assurance tools for java. In *Proceedings of the 32nd ACM SIGSOFT International Symposium on Software Testing and Analysis*. 285–297.
- [53] Haokun Liu, Derek Tam, Mohammed Muqeeth, Jay Mohta, Tenghao Huang, Mohit Bansal, and Colin Raffel. 2022. Few-shot parameter-efficient fine-tuning is better and cheaper than in-context learning. *Advances in Neural Information Processing Systems* 35 (2022), 1950–1965.
- [54] Jiawei Liu, Chunqiu Steven Xia, Yuyao Wang, and Lingming Zhang. 2024. Is your code generated by chatgpt really correct? rigorous evaluation of large language models for code generation. *Advances in Neural Information Processing Systems* 36 (2024).
- [55] Zhongxin Liu, Zhijie Tang, Junwei Zhang, Xin Xia, and Xiaohu Yang. 2024. Pre-training by Predicting Program Dependencies for Vulnerability Analysis Tasks. In *Proceedings of the IEEE/ACM 46th International Conference on Software Engineering*. 1–13.
- [56] Anton Lozhkov, Raymond Li, Loubna Ben Allal, Federico Cassano, Joel Lamy-Poirier, Nouamane Tazi, Ao Tang, Dmytro Pykhtar, Jiawei Liu, Yuxiang Wei, et al. 2024. StarCoder 2 and The Stack v2: The Next Generation. *arXiv preprint arXiv:2402.19173* (2024).
- [57] Fanxu Meng, Zhaohui Wang, and Muhan Zhang. 2024. Pissa: Principal singular values and singular vectors adaptation of large language models. *arXiv preprint arXiv:2404.02948* (2024).
- [58] Meta. 2023. CodeLlama. <https://huggingface.co/samxtr/codellama-7b/>
- [59] Meta. 2024. Llama3. <https://llama.meta.com/llama3/>
- [60] Microsoft. 2024. Phi3. <https://azure.microsoft.com/en-us/blog/introducing-phi-3-redefining-whats-possible-with-slm/>
- [61] Anh Nguyen-Duc, Manh Viet Do, Quan Luong Hong, Kiem Nguyen Khac, and Anh Nguyen Quang. 2021. On the adoption of static analysis for software security assessment—A case study of an open-source e-government project. *computers & security* 111 (2021), 102470.
- [62] Georgios Nikitopoulos, Konstantina Dritsa, Panos Louridas, and Dimitris Mitropoulos. 2021. CrossVul: a cross-language vulnerability dataset with commit data. In *Proceedings of the 29th ACM Joint Meeting on European Software Engineering Conference and Symposium on the Foundations of Software Engineering*. 1565–1569.
- [63] Paulo Nunes, Ibéria Medeiros, José Fonseca, Nuno Neves, Miguel Correia, and Marco Vieira. 2019. An empirical study on combining diverse static analysis tools for web security vulnerabilities based on development scenarios. *Computing* 101 (2019), 161–185.
- [64] The University of Maryland. 2022. SpotBugs. <https://spotbugs.github.io/>
- [65] National Institute of Standards and Technology. 2017. Juliet Test Suite. <https://samate.nist.gov/SARD/test-suites>
- [66] OpenAI. 2024. OpenAI GPT-3.5 (gpt-3.5-turbo-0125). <https://platform.openai.com/docs/guides/text-generation/chat-completions-api>
- [67] Tao Peng, Shixu Chen, Fei Zhu, Junwei Tang, Junping Liu, and Xinrong Hu. 2023. PTLVD: Program Slicing and Transformer-based Line-level Vulnerability Detection System. In *23rd IEEE International Working Conference on Source Code Analysis and Manipulation, SCAM 2023, Bogotá, Colombia, October 2-3, 2023*, Leon Moonen, Christian D. Newman, and Alessandra Gorla (Eds.). IEEE, 162–173. <https://doi.org/10.1109/SCAM59687.2023.00026>
- [68] Lina Qiu, Yingying Wang, and Julia Rubin. 2018. Analyzing the analyzers: Flow-droid/iccta, amandroid, and droidsafe. In *Proceedings of the 27th ACM SIGSOFT International Symposium on Software Testing and Analysis*. 176–186.
- [69] Contrast Security. 2022. Contrast Security. <https://www.contrastsecurity.com/>
- [70] Semgrep. 2022. Semgrep. <https://github.com/semgrep/semgrep>
- [71] SonarSource. 2022. SonarQube. <https://www.sonarqube.org/>
- [72] Statista. 2023. Number of common IT security vulnerabilities and exposures (CVEs) worldwide from 2009 to 2024 YTD. <https://www.statista.com/statistics/500755/worldwide-common-vulnerabilities-and-exposures/>
- [73] Darko Stefanović, Danilo Nikolić, Dušanka Dakić, Ivana Spasojević, and Sonja Ristić. 2020. Static code analysis tools: A systematic literature review. In *Ann. DAAAM Proc. Int. DAAAM Symp.* Vol. 31. 565–573.
- [74] Ferdian Thung, Lucia, David Lo, Lingxiao Jiang, Foyzur Rahman, and Premkumar T Devanbu. 2012. To what extent could we detect field defects? an empirical study of false negatives in static bug finding tools. In *Proceedings of the 27th IEEE/ACM International Conference on Automated Software Engineering*. 50–59.
- [75] TIOBE. 2024. TIOBE Index for May 2024. <https://www.tiobe.com/tiobe-index/>
- [76] David A Tomassi. 2018. Bugs in the wild: examining the effectiveness of static analyzers at finding real-world bugs. In *Proceedings of the 2018 26th ACM Joint Meeting on European Software Engineering Conference and Symposium on the Foundations of Software Engineering*. 980–982.
- [77] Marcos Treviso, Ji-Ung Lee, Tianchu Ji, Betty van Aken, Qingqing Cao, Manuel R Ciosici, Michael Hassid, Kenneth Heafield, Sara Hooker, Colin Raffel, et al. 2023. Efficient methods for natural language processing: A survey. *Transactions of the Association for Computational Linguistics* 11 (2023), 826–860.
- [78] Ashish Vaswani, Noam Shazeer, Niki Parmar, Jakob Uszkoreit, Llion Jones, Aidan N Gomez, Łukasz Kaiser, and Illia Polosukhin. 2017. Attention is all you need. *Advances in neural information processing systems* 30 (2017).
- [79] Yue Wang, Weishi Wang, Shafiq Joty, and Steven CH Hoi. 2021. Codet5: Identifier-aware unified pre-trained encoder-decoder models for code understanding and generation. *arXiv preprint arXiv:2109.00859* (2021).
- [80] Jason Wei, Maarten Bosma, Vincent Y Zhao, Kelvin Guu, Adams Wei Yu, Brian Lester, Nan Du, Andrew M Dai, and Quoc V Le. 2021. Finetuned language models are zero-shot learners. *arXiv preprint arXiv:2109.01652* (2021).

- [81] Xin-Cheng Wen, Xincheng Wang, Yujia Chen, Ruida Hu, David Lo, and Cuiyun Gao. 2024. VulEval: Towards Repository-Level Evaluation of Software Vulnerability Detection. *arXiv:2404.15596* [cs.SE]
- [82] Martin Weyssow, Xin Zhou, Kisub Kim, David Lo, and Houari Sahraoui. 2023. Exploring parameter-efficient fine-tuning techniques for code generation with large language models. *arXiv preprint arXiv:2308.10462* (2023).
- [83] Haitao Xu, Ruifeng Duan, Shengsong Yang, and Lei Guo. 2021. An empirical study on data sampling for just-in-time defect prediction. In *Artificial Intelligence and Security: 7th International Conference, ICAIS 2021, Dublin, Ireland, July 19–23, 2021, Proceedings, Part II* 7. Springer, 54–69.
- [84] Xu Yang, Shaowei Wang, Yi Li, and Shaohua Wang. 2023. Does data sampling improve deep learning-based vulnerability detection? Yeas! and Nays!. In *45th IEEE/ACM International Conference on Software Engineering, ICSE 2023, Melbourne, Australia, May 14–20, 2023*. IEEE, 2287–2298. <https://doi.org/10.1109/ICSE48619.2023.00192>
- [85] Junwei Zhang, Zhongxin Liu, Xing Hu, Xin Xia, and Shanping Li. 2023. Vulnerability Detection by Learning From Syntax-Based Execution Paths of Code. *IEEE Trans. Software Eng.* 49, 8 (2023), 4196–4212. <https://doi.org/10.1109/TSE.2023.3286586>
- [86] Xin Zhou, Kisub Kim, Bowen Xu, Jiakun Liu, DongGyun Han, and David Lo. 2023. The devil is in the tails: How long-tailed code distributions impact large language models. In *2023 38th IEEE/ACM International Conference on Automated Software Engineering (ASE)*. IEEE, 40–52.
- [87] Xin Zhou, Ting Zhang, and David Lo. 2024. Large Language Model for Vulnerability Detection: Emerging Results and Future Directions. *ICSE NIER track* (2024).
- [88] Yaqin Zhou, Shangqing Liu, Jingkai Siow, Xiaoning Du, and Yang Liu. 2019. Devign: Effective vulnerability identification by learning comprehensive program semantics via graph neural networks. *Advances in neural information processing systems* 32 (2019).
- [89] Zupit. 2022. Horusec. <https://docs.horusec.io/docs/overview/>